

****Police Report****

****Netcompany Recommended for Fine****

****Date: 12-01-2024****

****Decision****

****Private Companies****

****Police Report****

****Reported Breach of Personal Data Security****

****Processing Security****

****Sensitive Information****

****Risk Assessment and Impact Analysis****

****CPR Number****

****Unauthorized Access****

The Data Protection Agency reports Netcompany to the police and recommends a fine of at least 15 million DKK. In the development of mit.dk, the company did not ensure an appropriate level of security, and a consequence analysis should have been prepared, according to the agency.

Netcompany has been recommended for a fine of no less than 15 million DKK for violating the General Data Protection Regulation (GDPR) on several occasions, as the company, as the data controller, did not implement appropriate security measures in connection with the development of mit.dk, including failing to ensure that appropriate security measures were integrated into the design of the solution—so-called privacy by design—and for not having prepared a consequence analysis in connection with the development of mit.dk.

****Inappropriate Coding Allowed Access to Other Users' Information****

The IT solution mit.dk is operated and owned by Netcompany, and citizens and businesses can choose to use the solution to access digital mail from, among others, public authorities.

In connection with the development of mit.dk, Netcompany used inappropriate coding in the component that is supposed to authenticate users of mit.dk. When the solution was launched on March 22, 2022, an error almost immediately occurred when multiple users logged into the solution simultaneously—this error allowed users unauthorized access to other users' digital mail and thus to personal data of both confidential and sensitive nature. This resulted in an unnecessarily high risk for all users of mit.dk.

Netcompany became aware of the inappropriate coding shortly after the launch of mit.dk when several users contacted the company about being able to access other users' information. The solution was then shut down until the inappropriate coding was rectified, and the breach was reported to the Data Protection Agency.

****Critical Risk Scenarios Must Be in Focus****

Before the launch of mit.dk, a series of tests were conducted, including code reviews, static code analysis, and performance tests, but the inappropriate coding was not detected.

The Data Protection Agency believes that, considering the purpose of mit.dk, one of the most critical and obvious risks of the solution was that other users gained access to digital mail that they were not authorized to access, including mail containing confidential and sensitive information.

"When developing IT solutions, one must—before starting to process personal data—identify the specific risks and especially the most critical risk scenarios that the individual IT solution may entail, so that appropriate security measures can be taken into account. And when subsequently testing the solution, it is crucial that there is extra focus on the particularly critical risk scenarios. This way, one can select and conduct precisely those tests that are relevant and necessary to catch critical errors in time," says Vibeke Dyssemark Thomsen, Chief Consultant at the Data Protection Agency.

Considering the purpose of mit.dk, the personal data accessed, and the large number of users who were to use the solution, the Data Protection Agency further assesses that the administration and use of mit.dk involved a high risk for users. However, a consequence analysis had not been prepared.

"Preparing a consequence analysis is not a formality. The analysis is a significant legal security guarantee for citizens' rights when the processing of their information carries an inherent high risk. The work on such an analysis involves a thorough and structured process that provides a better and more

detailed overview of the risks associated with a particular solution, as well as identifying and implementing the necessary measures to address and reduce the risk. The consequence analysis must be completed before processing begins, so one can be sure that all central risks are managed and all high risks mitigated," explains Vibeke Dyssemark Thomsen.

****Why Police Report?****

The Data Protection Agency always conducts a specific assessment of the severity of the case pursuant to Article 83, paragraph 2 of the GDPR when evaluating which sanction, in the agency's opinion, is appropriate.

In this case, the Data Protection Agency believes there was both a deficient process regarding the consequence analysis, inappropriate coding that should not have been used for this type of solution, as well as that better testing of the solution before deployment should have uncovered the error, so the solution did not fail immediately upon deployment.

"The Danish society is highly digitized, and therefore it is crucial that citizens can trust that the security of the national critical infrastructure is in order. A case like this can undermine that trust, and for this reason, the Data Protection Agency must take strong action. Solutions like mit.dk must manage citizens' data responsibly, securely, and with respect for individual privacy," says Vibeke Dyssemark Thomsen.

This is the largest fine that the Data Protection Agency has recommended to date. In addition to the seriousness of the case, the amount also reflects that it concerns a very large company. It follows from the GDPR that fines in each individual case must be effective, proportionate to the violation, and have a deterrent effect.

****Want to Know More?****

You can read more about consequence analyses [here](#).

Press inquiries can be directed to Communications Consultant Anders Due at tel. 29 49 32 83.